ISO/IEC 27701:2025

TABLA A.1 — CONTROLES PARA RESPONSABLES DE PII (PII CONTROLLERS)

Sección A.1.4: Privacy by design & by default | Sección A.1.5: PII sharing, transfer & disclosure

---

INFORME TÉCNICO Y PERITAJE DE AUDITORÍA DE SISTEMAS

Caso de Estudio: Universidad Nacional de San Agustín de Arequipa (UNSA)

DATOS DE LA EVALUACIÓN Y EQUIPO AUDITOR:

- Institución Evaluada: Universidad Nacional de San Agustín de Arequipa (UNSA)
- Alcance Normativo: 13 Controles (A.1.4.2 a A.1.4.10 y A.1.5.2 a A.1.5.5 de ISO/IEC 27701:2025)
- Marco Jurídico Peruano: Ley N° 29733, D.S. N° 016-2024-JUS, Ley N° 30220, Ley N° 27806
- Auditor Líder: Ing. Rafael (MSc. Ciberseguridad & Auditoría TI, Lead Auditor ISO 27001, CISA, CRISC)
- Enfoque de Evaluación: Arquitectura de Sistemas, Ciclo de Vida del Dato y Flujo Transfronterizo Cloud
- Articulación con Proyecto de Tesis: Soporte de Privacidad para el Agente Inteligente DSAR (TIF-DSAR)

Arequipa, Perú — Semestre Académico 2026

Marco Normativo y Matriz de Riesgos (Secciones A.1.4 y A.1.5)

Las secciones A.1.4 ('Privacy by design & by default') y A.1.5 ('PII sharing, transfer & disclosure') de la norma ISO/IEC 27701:2025 representan el núcleo operativo de la protección de datos en la arquitectura tecnológica. Abarcan desde la minimización y depuración de bases de datos hasta la legalidad de transferencias transfronterizas (Google Cloud, Microsoft Azure) y convenios de intercambio estudiantil bajo la Ley N° 29733 y el D.S. N° 016-2024-JUS.

A continuación, se resume el diagnóstico de madurez institucional y criticidad de riesgo para los 13 controles:

Código	Control ISO/IEC 27701:2025	Alcance Técnico y Legal	Madurez	Riesgo	Pág.
A.1.4.2	Limit collection	Minimización de campos en recolección	Nivel 2	Medio	Pág. 3
A.1.4.3	Limit processing	Finalidad legítima y no reutilización indebida	Nivel 2	Alto	Pág. 4
A.1.4.4	Accuracy and quality	Calidad y validación de datos (PIDE-RENIEC)	Nivel 3	Medio	Pág. 5
A.1.4.5	PII minimization objectives	Metas de minimización y seudonimización	Nivel 1	Alto	Pág. 6
A.1.4.6	PII de-identification/deletion	Anonimización y purga de postulantes	Nivel 1	Alto	Pág. 7
A.1.4.7	Temporary files	Ciclo de vida y destrucción de temporales	Nivel 2	Medio	Pág. 8
A.1.4.8	Retention	Plazos de retención y tablas de conservación	Nivel 2	Alto	Pág. 9
A.1.4.9	Disposal	Procedimientos de desecho físico y borrado seguro	Nivel 1	Crítico	Pág. 10
A.1.4.10	PII transmission controls	Cifrado en tránsito y enlaces de red (TLS/VPN)	Nivel 2	Alto	Pág. 11
A.1.5.2	Basis for PII transfer between jurisdictions	Licitud de Flujo Transfronterizo (Cloud)	Nivel 1	Crítico	Pág. 12
A.1.5.3	Countries & international orgs for transfer	Mapeo de países receptores (Erasmus/Purdue)	Nivel 2	Medio	Pág. 13
A.1.5.4	Records of transfer of PII	Bitácora y contratos DPA con terceros/bancos	Nivel 1	Alto	Pág. 14
A.1.5.5	Records of PII disclosures to 3rd parties	Registro de entregas judiciales, policiales y fiscalía	Nivel 2	Alto	Pág. 15

Nota metodológica: La escala de madurez se basa en CMMI/ISO 15504 (Nivel 1: Inicial/Ad-hoc; Nivel 2: Gestionado; Nivel 3: Definido; Nivel 4: Medido cuantitativamente; Nivel 5: Optimizado). El análisis conecta directamente con los requerimientos técnicos del proyecto TIF-DSAR de la UNSA.

Control A.1.4.2 — Limit collection

« Limitar la recopilación al mínimo proporcional » | Dominio: A.1.4 Privacy by design & default

TEXTO NORMATIVO ISO/IEC 27701:2025:
"The organization shall limit the collection of PII to the minimum that is relevant, proportional and necessary for the identified purposes."

1. EXPLICACIÓN GENERAL DEL CONTROL (Concepto Universal)

• **¿Qué significa en lenguaje sencillo?:** Exige no recolectar datos personales 'por si acaso' ni por costumbre administrativa. Solo debe solicitarse lo estrictamente necesario para brindar el servicio.
• ***Analogía de la vida real:*** *Formulario de un gimnasio que solicita religión, tipo de sangre y los ingresos de tus padres para solo permitirte usar las pesas. Absurdo y desproporcionado.*

2. ¿APLICA EN LA UNSA Y CUÁL ES SU ESTADO ACTUAL?

• **Diagnóstico de Aplicabilidad: APLICA OBLIGATORIAMENTE (Estado Actual: Nivel 2 - Gestionado informalmente).**
• **Sustento técnico-legal:** Exigido por el Principio de Proporcionalidad del Art. 6 de la Ley 29733 y Art. 12 del D.S. 016-2024-JUS. En la UNSA, formularios de comedor (DUS) y admisión solicitan datos no indispensables sin justificación de necesidad.

3. PERSPECTIVA DE LA UNIVERSIDAD (UNSA) — IMPLEMENTACIÓN OPERATIVA

• **Marco y Antecedentes Estatales:** *Marco de simplificación administrativa D.S. 004-2019-JUS y directivas de gobierno digital de la PCM.*
• **WHEN (Cuándo):** En la fase de diseño de formularios web, previo al lanzamiento de cada proceso de matrícula y admisión.
• **HOW (Cómo):** Revisión de atributos en formularios SISCA, eliminando campos obligatorios superfluos y documentando la necesidad de cada dato.
• **WHO (Quién):** DUIC, Dirección Universitaria de Desarrollo Estudiantil y Bienestar (DUS) y Oficina de Admisión.
• **WHAT (Qué entregables):** Matriz de Justificación de Datos por Formulario e inventario de campos aprobados por el Oficial de Privacidad.
• **WHERE (Dónde se ubica):** Módulo de matrícula SISCA y portal web de postulantes (webadmision.unsa.edu.pe).

4. PERSPECTIVA DEL AUDITOR (Ing. Rafael) — MADUREZ: NIVEL 2 (Gestionado) | RIESGO: MEDIO

• **Observaciones de Auditoría (GAP):** La ficha socioeconómica del Comedor Universitario y encuestas de bienestar solicitan filiación política, credos y bienes de parientes lejanos sin justificación funcional, exponiendo a multas de la ANPDP.
• **Recomendaciones de Remediación:** Auditar técnicamente todos los formularios de captura y eliminar campos no esenciales; formular directiva obligatoria de 'Data Minimization in Forms' para los desarrolladores de la DUIC.

5. GUIONES DE EXPOSICIÓN ORAL — CONTROL A.1.4.2

• **Guión Como Universidad (UNSA):** *"Como universidad pública garantizamos que los formularios en SISCA no recojan datos superfluos. Estamos en una campaña de simplificación digital donde solo se pide lo estrictamente necesario para registrar al alumno y validar su condición socioeconómica."*
• **Guión Como Auditor (Ing. Rafael):** *"Durante la auditoría evidencio que la UNSA pide datos excesivos como filiación política e ingresos de parientes en trámites de comedor. La ISO 27701 y la Ley 29733 sancionan pedir datos por si acaso; debe podarse el modelo de datos de producción."*

Control A.1.4.3 — Limit processing

« Limitar el tratamiento a fines legítimos y autorizados » | Dominio: A.1.4 Privacy by design & default

TEXTO NORMATIVO ISO/IEC 27701:2025:
"The organization shall limit the processing of PII to that which is adequate, relevant and necessary for the identified purposes."

1. EXPLICACIÓN GENERAL DEL CONTROL (Concepto Universal)

• **¿Qué significa en lenguaje sencillo?:** Los datos personales recopilados para un fin específico (ej. notas) no pueden ser usados para otros propósitos ajenos (ej. proselitismo político o encuestas comerciales) sin consentimiento.
• ***Analogía de la vida real:*** *Dejar tu teléfono en una clínica para que te avisen del resultado de un análisis de sangre, y que luego el personal lo use para invitarte a afiliarte a un partido político.*

2. ¿APLICA EN LA UNSA Y CUÁL ES SU ESTADO ACTUAL?

• **Diagnóstico de Aplicabilidad: APLICA TOTALMENTE (Estado Actual: Nivel 2 - Gestionado con deficiencias).**
• **Sustento técnico-legal:** Principio de Finalidad (Art. 5 Ley 29733 y Art. 11 D.S. 016-2024-JUS). En la UNSA se suelen reutilizar correos institucionales @unsa.edu.pe y padrones para enviar comunicados electorales o investigaciones externas sin autorización.

3. PERSPECTIVA DE LA UNIVERSIDAD (UNSA) — IMPLEMENTACIÓN OPERATIVA

• **Marco y Antecedentes Estatales:** *Código de Ética de la Función Pública y Estatuto Universitario que prohíben el desvío de recursos informáticos.*
• **WHEN (Cuándo):** En cada consulta a la base de datos, generación de reportes masivos y ejecución de procesos batch.
• **HOW (Cómo):** Implementando control de acceso basado en roles (RBAC) y restringiendo exportaciones masivas de datos de alumnos sin autorización formal.
• **WHO (Quién):** Administrador de Base de Datos (DBA DUIC), Oficial de Seguridad (CISO) y Secretaría General.
• **WHAT (Qué entregables):** Política de Uso Aceptable de Bases de Datos y bitácora de auditoría de consultas SQL (Audit Logs).
• **WHERE (Dónde se ubica):** Servidores centrales de base de datos PostgreSQL/Oracle en el Data Center San Agustín.

4. PERSPECTIVA DEL AUDITOR (Ing. Rafael) — MADUREZ: NIVEL 2 (Parcial) | RIESGO: ALTO

• **Observaciones de Auditoría (GAP):** No existen barreras lógicas a nivel de base de datos para impedir que dependencias administrativas descarguen padrones completos y los reutilicen para comunicaciones proselitistas o personales no consentidas.
• **Recomendaciones de Remediación:** Configurar vistas restringidas (Views) con enmascaramiento dinámico (Dynamic Masking) y exigir aprobación formal del Oficial de Datos para descargas masivas.

5. GUIONES DE EXPOSICIÓN ORAL — CONTROL A.1.4.3

• **Guión Como Universidad (UNSA):** *"En la UNSA velamos por el principio de finalidad. Los datos del alumno solo se procesan para su formación académica, bienestar y titulación, impidiendo que su correo o legajo sea utilizado para fines ajenos a la vida universitaria."*
• **Guión Como Auditor (Ing. Rafael):** *"Como auditor observo que docentes y jefes de departamento pueden exportar hojas de cálculo completas con correos y teléfonos y usarlas discrecionalmente. La ISO 27701 exige barreras técnicas estrictas para impedir tratamientos secundarios no autorizados."*

Control A.1.4.4 — Accuracy and quality

« Exactitud, integridad y calidad de datos personales » | Dominio: A.1.4 Privacy by design & default

TEXTO NORMATIVO ISO/IEC 27701:2025:
"The organization shall ensure and document that PII is as accurate, complete and up to date as necessary for the purposes for which it is processed, throughout the life cycle of the PII."

1. EXPLICACIÓN GENERAL DEL CONTROL (Concepto Universal)

• **¿Qué significa en lenguaje sencillo?:** Los datos deben ser exactos, verdaderos y mantenerse actualizados. Un error en un apellido o DNI puede ocasionar que un estudiante no se gradúe a tiempo o pierda un beneficio universitario.
• ***Analogía de la vida real:*** *Que en el banco registren mal un dígito de tu DNI y tu salario sea transferido a otra persona o te reporten erróneamente por deuda ajena.*

2. ¿APLICA EN LA UNSA Y CUÁL ES SU ESTADO ACTUAL?

• **Diagnóstico de Aplicabilidad: APLICA TOTALMENTE (Estado Actual: Nivel 3 - Definido en identidad, deficiente en contacto).**
• **Sustento técnico-legal:** Principio de Calidad (Art. 8 Ley 29733 / D.S. 016-2024-JUS) y Art. 47 Ley Universitaria 30220. La UNSA valida identidad con RENIEC vía PIDE para títulos, pero los datos de contacto y salud están desactualizados.

3. PERSPECTIVA DE LA UNIVERSIDAD (UNSA) — IMPLEMENTACIÓN OPERATIVA

• **Marco y Antecedentes Estatales:** *Interoperabilidad del Estado Peruano (PIDE-PCM) con RENIEC para validación registral fidedigna.*
• **WHEN (Cuándo):** En la inscripción de postulantes, al inicio de la matrícula semestral y previo a la emisión de grados.
• **HOW (Cómo):** Consumo de web services REST/SOAP de RENIEC para validar nombres y DNI; habilitación de formulario obligatorio de actualización de teléfonos y correos en SISCA.
• **WHO (Quién):** Oficina de Grados y Títulos, Dirección de Informática (DUIC) y Mesa de Partes.
• **WHAT (Qué entregables):** Reportes de validación de identidad digital y protocolo de cotejo biográfico fidedigno.
• **WHERE (Dónde se ubica):** Módulo de Registro Académico SISCA y pasarela de interoperabilidad institucional.

4. PERSPECTIVA DEL AUDITOR (Ing. Rafael) — MADUREZ: NIVEL 3 (Definido) | RIESGO: MEDIO

• **Observaciones de Auditoría (GAP):** Aunque el DNI se valida contra RENIEC para grados, más del 65% de los registros de estudiantes en SISCA poseen números telefónicos y domicilios obsoletos sin actualizar, arriesgando la validez de notificaciones.
• **Recomendaciones de Remediación:** Establecer bloqueo de matrícula semestral en SISCA que exija validación de celular vía OTP (código SMS/correo) e implementar log de trazabilidad de cambios biográficos.

5. GUIONES DE EXPOSICIÓN ORAL — CONTROL A.1.4.4

• **Guión Como Universidad (UNSA):** *"Garantizamos la calidad de los datos conectándonos en tiempo real con RENIEC a través de la PIDE. De este modo, los nombres y números de documento remitidos a SUNEDU y consignados en los diplomas son 100% exactos."*
• **Guión Como Auditor (Ing. Rafael):** *"Felicito la integración con RENIEC para títulos, pero la calidad del dato abarca todo el ciclo de vida. Los teléfonos y domicilios de los alumnos están desactualizados desde que postulan, invalidando notificaciones legales. Debe remediarse."*

Control A.1.4.5 — PII minimization objectives

« Objetivos formales de minimización y seudonimización » | Dominio: A.1.4 Privacy by design & default

TEXTO NORMATIVO ISO/IEC 27701:2025:
"The organization shall define and document data minimization objectives and what mechanisms (such as de-identification) are used to meet those objectives."

1. EXPLICACIÓN GENERAL DEL CONTROL (Concepto Universal)

• **¿Qué significa en lenguaje sencillo?:** La organización debe fijarse metas escritas y métricas para reducir la cantidad de datos que almacena, aplicando técnicas como seudonimizar o disociar para no usar datos reales.
• ***Analogía de la vida real:*** *Una empresa que se fija como meta reducir el consumo de papel un 40% anual e implementa software digital. Aquí la meta es reducir datos personales y usar códigos en vez de nombres.*

2. ¿APLICA EN LA UNSA Y CUÁL ES SU ESTADO ACTUAL?

• **Diagnóstico de Aplicabilidad: APLICA (Estado Actual: Nivel 1 - Inicial / No implementado formalmente).**
• **Sustento técnico-legal:** Fomento de la seudonimización y disociación en el D.S. 016-2024-JUS. Actualmente la UNSA NO tiene metas documentadas de minimización; los desarrolladores conservan tablas enteras sin disociar.

3. PERSPECTIVA DE LA UNIVERSIDAD (UNSA) — IMPLEMENTACIÓN OPERATIVA

• **Marco y Antecedentes Estatales:** *Plan de Gobierno Digital Institucional y directivas de ciencia abierta de CONCYTEC.*
• **WHEN (Cuándo):** Al formular arquitecturas de nuevos sistemas y al proveer datasets para tesis de investigación.
• **HOW (Cómo):** Aplicando funciones hash (SHA-256) sobre DNI para generar identificadores opacos (UUIDs) que permitan análisis estadístico sin exponer la identidad personal.
• **WHO (Quién):** Vicerrectorado de Investigación (VRI), Comité de Gobierno Digital y Área de Desarrollo DUIC.
• **WHAT (Qué entregables):** Política Institucional de Minimización y Seudonimización y catálogo de datasets disociados.
• **WHERE (Dónde se ubica):** Repositorio institucional de investigación y servidores analíticos de la UNSA.

4. PERSPECTIVA DEL AUDITOR (Ing. Rafael) — MADUREZ: NIVEL 1 (Inicial) | RIESGO: ALTO

• **Observaciones de Auditoría (GAP):** No existen objetivos documentados de minimización ni indicadores (KPIs). En tesis de medicina y ciencias sociales se manipulan hojas de cálculo con datos reales sin ofuscación, arriesgando filtraciones.
• **Recomendaciones de Remediación:** Fijar por política que el 100% de datasets entregados a tesistas deben ser seudonimizados; habilitar entornos de prueba (QA) con datos sintéticos o enmascarados.

5. GUIONES DE EXPOSICIÓN ORAL — CONTROL A.1.4.5

• **Guión Como Universidad (UNSA):** *"La universidad viene incorporando la desidentificación como estándar de trabajo. En las investigaciones y estadísticas de deserción estudiantil, los nombres y DNI son sustituidos por identificadores aleatorios, resguardando la privacidad."*
• **Guión Como Auditor (Ing. Rafael):** *"Durante la auditoría no encontré ninguna meta escrita de minimización. Los tesistas e investigadores manejan datos reales con DNI y nombres completos sin tokenización previa. La norma exige metas claras y mecanismos de seudonimización documentados."*

Control A.1.4.6 — PII de-identification/deletion

« Desidentificación y supresión al término del tratamiento » | Dominio: A.1.4 Privacy by design & default

TEXTO NORMATIVO ISO/IEC 27701:2025:
"The organization shall either delete PII or render it in a form which does not permit identification or re-identification of PII principals, as soon as the original PII is no longer necessary for the identified purpose(s)."

1. EXPLICACIÓN GENERAL DEL CONTROL (Concepto Universal)

• **¿Qué significa en lenguaje sencillo?:** Cuando se cumple el propósito para el que se recopiló el dato (ej. terminó el examen para postulantes que no ingresaron), este debe destruirse o anonimizarse irreversiblemente.
• ***Analogía de la vida real:*** *Triturar el contrato de alquiler cuando ya te mudaste, devolviste la llave y liquidaste las cuentas, o borrar las grabaciones de videovigilancia cumplido el mes reglamentario.*

2. ¿APLICA EN LA UNSA Y CUÁL ES SU ESTADO ACTUAL?

• **Diagnóstico de Aplicabilidad: APLICA TOTALMENTE (Estado Actual: Nivel 1 - Deficiente / Acumulación pasiva).**
• **Sustento técnico-legal:** Exigido por el Art. 21 de la Ley 29733 (Cancelación por fin de finalidad) y Art. 19 del D.S. 016-2024-JUS. En la UNSA se conservan bases de postulantes no ingresantes de hace más de una década con fotos y huellas.

3. PERSPECTIVA DE LA UNIVERSIDAD (UNSA) — IMPLEMENTACIÓN OPERATIVA

• **Marco y Antecedentes Estatales:** *Normas del Archivo General de la Nación (AGN) y directivas de la ANPDP sobre disociación definitiva.*
• **WHEN (Cuándo):** A los 12 meses de culminado cada proceso de admisión para postulantes no ingresantes.
• **HOW (Cómo):** Mediante scripts SQL automatizados que anonimizan los registros en la base de datos de admisión y eliminan imágenes biométricas del storage, reteniendo solo métricas agregadas.
• **WHO (Quién):** Oficina Universitaria de Admisión, DUIC y Archivo Central Universitario.
• **WHAT (Qué entregables):** Script automatizado de anonimización y Acta de Depuración Segura de Bases de Datos de Postulantes.
• **WHERE (Dónde se ubica):** Bases de datos de admisión (MySQL/PostgreSQL) y almacenamiento NAS de evidencias.

4. PERSPECTIVA DEL AUDITOR (Ing. Rafael) — MADUREZ: NIVEL 1 (Inicial) | RIESGO: ALTO

• **Observaciones de Auditoría (GAP):** Se evidencian más de 120,000 registros de postulantes no admitidos (2015-2024) con fotografías faciales y huellas dactilares almacenados sin anonimizar ni justificación vigente, creando un pasivo legal de alto riesgo.
• **Recomendaciones de Remediación:** Ejecutar purga segura con técnicas de k-anonimato para postulantes de años anteriores a 2024; formalizar el procedimiento de 'Disociación Automatizada' mediante resolución rectoral.

5. GUIONES DE EXPOSICIÓN ORAL — CONTROL A.1.4.6

• **Guión Como Universidad (UNSA):** *"Para los postulantes no ingresantes, la universidad está implementando un protocolo de disociación para que tras un año del examen, sus datos biométricos se supriman y solo queden estadísticas agregadas."*
• **Guión Como Auditor (Ing. Rafael):** *"Mantener almacenadas fotos y huellas de 120,000 postulantes que no ingresaron hace años es una bomba de tiempo. Si esa base sufre una fuga, la sanción de la ANPDP será catastrófica. Se debe anonimizar o destruir de inmediato."*

Control A.1.4.7 — Temporary files

« Destrucción y ciclo de vida de archivos temporales » | Dominio: A.1.4 Privacy by design & default

TEXTO NORMATIVO ISO/IEC 27701:2025:
"The organization shall ensure that temporary files created as a result of the processing of PII are disposed of (e.g. erased or destroyed) following documented procedures within a specified, documented period."

1. EXPLICACIÓN GENERAL DEL CONTROL (Concepto Universal)

• **¿Qué significa en lenguaje sencillo?:** Cuando un sistema procesa datos (exportar notas a Excel, generar carnés en PDF), crea archivos temporales. Estos deben borrarse automáticamente y no quedar abandonados en servidores o PCs.
• ***Analogía de la vida real:*** *Sacar copia de tu DNI en una librería y que el dueño guarde una fotocopia extra en un cajón abierto al alcance de cualquier persona que entre al local.*

2. ¿APLICA EN LA UNSA Y CUÁL ES SU ESTADO ACTUAL?

• **Diagnóstico de Aplicabilidad: APLICA TOTALMENTE (Estado Actual: Nivel 2 - Gestionado informalmente).**
• **Sustento técnico-legal:** Directiva de Seguridad de la Información (ANPDP, gestión de soportes temporales) y Art. 38 D.S. 016-2024-JUS. En la UNSA los servidores web acumulan exportaciones en `/tmp` sin políticas de limpieza.

3. PERSPECTIVA DE LA UNIVERSIDAD (UNSA) — IMPLEMENTACIÓN OPERATIVA

• **Marco y Antecedentes Estatales:** *Buenas prácticas del Centro Nacional de Seguridad Digital (CNSD-PCM) para administración segura de servidores.*
• **WHEN (Cuándo):** Diariamente en ejecución nocturna programada (02:00 hrs) y al cierre de cada sesión de reporte.
• **HOW (Cómo):** Configuración de cron jobs en servidores Linux que ejecutan borrado seguro (`shred`) en carpetas `/tmp` y `/var/www/temp` con antigüedad mayor a 24 horas.
• **WHO (Quién):** Administradores de Servidores de la DUIC y Oficial de Seguridad de la Información.
• **WHAT (Qué entregables):** Script de purga automatizada de temporales y registros en bitácora (Log de Depuración).
• **WHERE (Dónde se ubica):** Servidores web del SISCA, contenedores Docker y computadoras de secretarías académicas.

4. PERSPECTIVA DEL AUDITOR (Ing. Rafael) — MADUREZ: NIVEL 2 (Parcial) | RIESGO: MEDIO

• **Observaciones de Auditoría (GAP):** Se hallaron más de 45 GB de archivos temporales con padrones de alumnos y notas en el directorio `/var/tmp/reports/` del servidor web principal con fechas que datan del 2021, vulnerando el principio de seguridad.
• **Recomendaciones de Remediación:** Establecer parámetro estricto de Time-To-Live (TTL) de 24 horas para archivos temporales con datos personales; aplicar directiva de borrado seguro en puestos de trabajo.

5. GUIONES DE EXPOSICIÓN ORAL — CONTROL A.1.4.7

• **Guión Como Universidad (UNSA):** *"En los servidores de la UNSA hemos programado tareas automáticas que barren los directorios temporales cada 24 horas. Todo reporte en PDF o Excel generado para un trámite es destruido automáticamente sin dejar rastro."*
• **Guión Como Auditor (Ing. Rafael):** *"En la inspección técnica encontré 45 gigabytes de reportes temporales con nombres, notas y teléfonos desprotegidos desde el 2021. La creación de temporales sin destrucción documentada es una brecha crítica muy explotada por atacantes."*

Control A.1.4.8 — Retention

« Plazos de retención y límites de conservación de datos » | Dominio: A.1.4 Privacy by design & default

TEXTO NORMATIVO ISO/IEC 27701:2025:
"The organization shall not retain PII for longer than is necessary for the purposes for which the PII is processed."

1. EXPLICACIÓN GENERAL DEL CONTROL (Concepto Universal)

• **¿Qué significa en lenguaje sencillo?:** Los datos no pueden guardarse para siempre sin justificación. Debe existir un calendario formal que fije cuánto tiempo se guarda cada tipo de dato y cuándo debe eliminarse o archivarse.
• ***Analogía de la vida real:*** *Guardar las recetas médicas de la gripe que tuviste a los 5 años en la gaveta de tu oficina cuando ya tienes 40 años. No tiene utilidad alguna.*

2. ¿APLICA EN LA UNSA Y CUÁL ES SU ESTADO ACTUAL?

• **Diagnóstico de Aplicabilidad: APLICA CON ARMONIZACIÓN NORMATIVA (Estado Actual: Nivel 2 - Gestionado parcialmente).**
• **Sustento técnico-legal:** Principio de Limitación de Conservación (Art. 13 D.S. 016-2024-JUS). Las actas de notas se guardan permanentemente por Ley Universitaria 30220 y el AGN; pero videos y salud deben caducar.

3. PERSPECTIVA DE LA UNIVERSIDAD (UNSA) — IMPLEMENTACIÓN OPERATIVA

• **Marco y Antecedentes Estatales:** *Tabla de Retención Documental del Sistema Nacional de Archivos y exigencias de SUNEDU.*
• **WHEN (Cuándo):** En la captura del dato y semestralmente en la revisión del inventario de bancos de datos.
• **HOW (Cómo):** Aprobando la Tabla de Retención Universitaria: Notas y títulos (Permanente), Videovigilancia (45 días), Fichas médicas de bienestar (5 años post-egreso), Control de acceso (1 año).
• **WHO (Quién):** Archivo Central de la UNSA, Secretaría General, Asuntos Académicos y DUIC.
• **WHAT (Qué entregables):** Política Universitaria de Retención de Datos y Tabla de Plazos de Conservación.
• **WHERE (Dónde se ubica):** Archivo Central (Calle Santa Catalina) y bases de datos transaccionales de la DUIC.

4. PERSPECTIVA DEL AUDITOR (Ing. Rafael) — MADUREZ: NIVEL 2 (Parcial) | RIESGO: ALTO

• **Observaciones de Auditoría (GAP):** La universidad asume erróneamente que todo dato debe guardarse por siempre. Se conservan videos de vigilancia de años pasados y legajos de personal inactivo sin reglas de expiración ni justificación legal.
• **Recomendaciones de Remediación:** Aprobar mediante Consejo Universitario la Tabla de Retención de Datos Personales que distinga registros históricos de temporales, programando la sobreescritura automática de cámaras.

5. GUIONES DE EXPOSICIÓN ORAL — CONTROL A.1.4.8

• **Guión Como Universidad (UNSA):** *"La UNSA custodia la historia académica de la región y por mandato de SUNEDU nuestras actas son eternas. Sin embargo, hemos normado que datos no académicos, como cámaras de seguridad y citas médicas, tengan plazos estrictos de caducidad."*
• **Guión Como Auditor (Ing. Rafael):** *"El error de la universidad pública es decir que aquí no se borra nada. Las notas se guardan por ley, pero mantener videos de vigilancia de hace tres años o datos médicos viejos vulnera el principio de limitación de conservación de la norma ISO."*

Control A.1.4.9 — Disposal

« Procedimientos de desecho físico y borrado seguro de datos » | Dominio: A.1.4 Privacy by design & default

TEXTO NORMATIVO ISO/IEC 27701:2025:
"The organization shall have documented policies, procedures or mechanisms for the disposal of PII."

1. EXPLICACIÓN GENERAL DEL CONTROL (Concepto Universal)

• **¿Qué significa en lenguaje sencillo?:** Cuando se descartan computadoras viejas o papeles con datos personales, debe haber una destrucción segura (trituración física o formateo magnético militar) para que nadie pueda recuperarlos.
• ***Analogía de la vida real:*** *Cortar en pedacitos diminutos una tarjeta de crédito vencida antes de botarla, en vez de tirarla entera a la bolsa de basura de la calle.*

2. ¿APLICA EN LA UNSA Y CUÁL ES SU ESTADO ACTUAL?

• **Diagnóstico de Aplicabilidad: APLICA OBLIGATORIAMENTE (Estado Actual: Nivel 1 - Inicial / Crítico).**
• **Sustento técnico-legal:** Directiva de Seguridad de la Información (ANPDP, medidas de destrucción física/digital) y Art. 38 D.S. 016-2024-JUS. Discos dados de baja en Control Patrimonial se almacenan o rematan sin borrado certificado.

3. PERSPECTIVA DE LA UNIVERSIDAD (UNSA) — IMPLEMENTACIÓN OPERATIVA

• **Marco y Antecedentes Estatales:** *Normativa de la SBN (Bienes Estatales) y OSCE sobre baja y disposición final de bienes muebles (RAEE).*
• **WHEN (Cuándo):** En los procesos anuales de baja patrimonial de equipos TI y en la depuración de acervo documental.
• **HOW (Cómo):** Aplicando sobreescritura de 3 pasos (NIST SP 800-88 / DoD 5220.22-M) con DBAN en discos duros, y trituración industrial de corte cruzado (DIN 66399 Nivel P-4) en papel.
• **WHO (Quién):** Oficina de Control Patrimonial, Soporte Técnico de la DUIC y Oficial de Seguridad de la Información.
• **WHAT (Qué entregables):** Procedimiento Operativo de Destrucción Segura y Actas Notariadas de Destrucción de Soportes.
• **WHERE (Dónde se ubica):** Almacenes de Control Patrimonial (Parque Industrial) y centros de datos de la DUIC.

4. PERSPECTIVA DEL AUDITOR (Ing. Rafael) — MADUREZ: NIVEL 1 (Inicial) | RIESGO: CRÍTICO

• **Observaciones de Auditoría (GAP):** Se inspeccionaron computadoras dadas de baja en almacén patrimonial y se constató que los discos mecánicos aún contenían bases de datos de planillas y legajos estudiantiles plenamente legibles y recuperables.
• **Recomendaciones de Remediación:** Aprobar con carácter de urgencia la Directiva de Borrado Seguro de Medios; adquirir un desmagnetizador (Degausser) y destructora P-4; exigir certificados antes de dar de baja cualquier PC.

5. GUIONES DE EXPOSICIÓN ORAL — CONTROL A.1.4.9

• **Guión Como Universidad (UNSA):** *"Estamos modernizando la disposición patrimonial en la UNSA. Ninguna computadora sale de la universidad para remate o reciclaje sin que antes la DUIC aplique borrado seguro certificado a sus discos."*
• **Guión Como Auditor (Ing. Rafael):** *"En la inspección física encontré discos en patrimonio con planillas y notas totalmente recuperables con software básico. Desechar equipos sin borrado criptográfico certificado es una negligencia crítica que expone a la universidad a demandas millonarias."*

Control A.1.4.10 — PII transmission controls

« Controles de seguridad en la transmisión de datos » | Dominio: A.1.4 Privacy by design & default

TEXTO NORMATIVO ISO/IEC 27701:2025:
"The organization shall subject PII transmitted (e.g. sent to another organization) over a data-transmission network to appropriate controls designed to ensure that the data reaches its intended destination."

1. EXPLICACIÓN GENERAL DEL CONTROL (Concepto Universal)

• **¿Qué significa en lenguaje sencillo?:** Cuando los datos viajan por internet o redes informáticas (enviar notas a SUNEDU, reportes al banco o conectar sedes provinciales), deben viajar cifrados y protegidos contra intercepciones.
• ***Analogía de la vida real:*** *Enviar un fajo de dinero usando un camión blindado con candados digitales y custodia, en lugar de meterlo en un sobre abierto con un mensajero en bicicleta.*

2. ¿APLICA EN LA UNSA Y CUÁL ES SU ESTADO ACTUAL?

• **Diagnóstico de Aplicabilidad: APLICA TOTALMENTE (Estado Actual: Nivel 2 - Gestionado parcialmente).**
• **Sustento técnico-legal:** Directiva de Seguridad de la Información (cifrado obligatorio en tránsito) y Art. 40 D.S. 016-2024-JUS. Portales principales usan TLS, pero existen subdominios y enlaces entre sedes provinciales con riesgos.

3. PERSPECTIVA DE LA UNIVERSIDAD (UNSA) — IMPLEMENTACIÓN OPERATIVA

• **Marco y Antecedentes Estatales:** *Lineamientos de la Red Nacional del Estado Peruano (REDDAP) y directrices de interoperabilidad de la PCM.*
• **WHEN (Cuándo):** En tiempo real en cada sesión de red y en transferencias masivas entre campus o entes externos.
• **HOW (Cómo):** Forzando TLS 1.3 con HSTS en portales web, túneles VPN IPsec con cifrado AES-256 hacia sedes de Camaná, Mollendo y Majes, y canales SFTP con llaves públicas para entidades bancarias.
• **WHO (Quién):** Área de Redes y Telecomunicaciones de la DUIC y Especialista en Ciberseguridad.
• **WHAT (Qué entregables):** Política de Cifrado en Comunicaciones y certificados digitales TLS institucionales vigentes.
• **WHERE (Dónde se ubica):** Enlaces de fibra óptica inter-campus, enlaces WAN provinciales y firewalls perimetrales.

4. PERSPECTIVA DEL AUDITOR (Ing. Rafael) — MADUREZ: NIVEL 2 (Parcial) | RIESGO: ALTO

• **Observaciones de Auditoría (GAP):** Se detectaron transferencias de padrones por correo electrónico común sin contraseña y subdominios de escuelas profesionales operando sobre HTTP plano sin cifrar, vulnerables a ataques MitM.
• **Recomendaciones de Remediación:** Habilitar la directiva global HSTS en el dominio unsa.edu.pe; prohibir el envío de bases de datos por correo simple; implementar una plataforma institucional de transferencia segura (MFT).

5. GUIONES DE EXPOSICIÓN ORAL — CONTROL A.1.4.10

• **Guión Como Universidad (UNSA):** *"Toda la interacción del estudiante con SISCA y con las sedes de Camaná y Mollendo está protegida con cifrado TLS y túneles VPN privados, evitando que un atacante pueda interceptar información en el camino."*
• **Guión Como Auditor (Ing. Rafael):** *"El portal principal tiene candado verde, pero identifiqué que subdominios de escuelas y envíos a bancos se hacen por canales sin cifrado robusto o correos vulnerables. La ISO 27701 exige controles criptográficos de extremo a extremo."*

Control A.1.5.2 — Basis for PII transfer

« Base legal para transferencias transfronterizas (Cloud) » | Dominio: A.1.5 PII sharing, transfer & disclosure

TEXTO NORMATIVO ISO/IEC 27701:2025:
"The organization shall identify and document the relevant basis for transfers of PII between jurisdictions."

1. EXPLICACIÓN GENERAL DEL CONTROL (Concepto Universal)

• **¿Qué significa en lenguaje sencillo?:** Si vas a enviar o alojar datos fuera de tu país (ej. correo Google, nube Azure, AWS o convenios universitarios extranjeros), debes tener una justificación legal documentada y válida según la ley de tu país.
• ***Analogía de la vida real:*** *Para enviar a tu hijo de viaje al extranjero en un intercambio escolar necesitas autorización notarial de viaje fundamentada ante migraciones; no puedes subirlo a un avión sin papeles legales.*

2. ¿APLICA EN LA UNSA Y CUÁL ES SU ESTADO ACTUAL?

• **Diagnóstico de Aplicabilidad: APLICA TOTALMENTE Y ES CRÍTICO (Estado Actual: Nivel 1 - Incumplimiento grave).**
• **Sustento técnico-legal:** Art. 15 de la Ley 29733 y Arts. 65 al 72 del D.S. 016-2024-JUS (Régimen de Flujo Transfronterizo). La UNSA usa masivamente Google Workspace y Azure en EE.UU./Europa SIN registro ante la ANPDP.

3. PERSPECTIVA DE LA UNIVERSIDAD (UNSA) — IMPLEMENTACIÓN OPERATIVA

• **Marco y Antecedentes Estatales:** *Directivas de la ANPDP sobre Flujo Transfronterizo y Marco de Adopción Cloud de la PCM.*
• **WHEN (Cuándo):** Previo a la contratación de cualquier servicio en la nube y anualmente ante el MINJUSDH.
• **HOW (Cómo):** Suscribiendo Cláusulas Contractuales Tipo (SCC), documentando la necesidad operativa del servicio educativo y registrando el flujo transfronterizo ante el Ministerio de Justicia.
• **WHO (Quién):** Oficina de Asesoría Jurídica, DUIC y Oficial de Protección de Datos de la UNSA.
• **WHAT (Qué entregables):** Expediente de Análisis de Impacto de Transferencia (TIA) y Registro de Flujo Transfronterizo.
• **WHERE (Dónde se ubica):** Dirección de Registro de la ANPDP (Lima/Virtual) y contratos suscritos con Google y Microsoft.

4. PERSPECTIVA DEL AUDITOR (Ing. Rafael) — MADUREZ: NIVEL 1 (Inicial) | RIESGO: CRÍTICO

• **Observaciones de Auditoría (GAP):** La UNSA almacena datos de más de 27,000 estudiantes y docentes en la nube internacional sin haber fundamentado la base de licitud ni haber registrado el flujo transfronterizo ante la ANPDP, arriesgando multas de 50 UIT.
• **Recomendaciones de Remediación:** Iniciar inmediatamente el procedimiento administrativo de comunicación de flujo transfronterizo ante la ANPDP amparado en el Art. 67 del D.S. 016-2024-JUS; formalizar los addendums DPA con Google y Microsoft.

5. GUIONES DE EXPOSICIÓN ORAL — CONTROL A.1.5.2

• **Guión Como Universidad (UNSA):** *"La UNSA ha adoptado tecnologías líderes como Google Workspace para brindar educación digital de calidad. Fundamentamos la transferencia internacional en la necesidad pedagógica y en que dichos proveedores cuentan con certificaciones ISO 27001."*
• **Guión Como Auditor (Ing. Rafael):** *"Tener contratado a Google o Microsoft no exime a la UNSA de la ley peruana. Alojar datos de 27,000 alumnos en EE.UU. sin haber registrado el flujo transfronterizo ante la ANPDP es una falta grave que expone a la universidad a severas sanciones."*

Control A.1.5.3 — Countries & intl organizations

« Países y organizaciones destinatarias de transferencias » | Dominio: A.1.5 PII sharing, transfer & disclosure

TEXTO NORMATIVO ISO/IEC 27701:2025:
"The organization shall specify and document the countries and international organizations to which PII can possibly be transferred."

1. EXPLICACIÓN GENERAL DEL CONTROL (Concepto Universal)

• **¿Qué significa en lenguaje sencillo?:** La institución debe publicar y documentar con claridad a qué países específicos y a qué organismos internacionales viajan o pueden viajar los datos personales. No puede haber opacidad geográfica.
• ***Analogía de la vida real:*** *Si depositas tus ahorros en una financiera, tienes derecho a saber si están custodiados en una bóveda local o colocados en fondos de inversión en Panamá o Islas Caimán.*

2. ¿APLICA EN LA UNSA Y CUÁL ES SU ESTADO ACTUAL?

• **Diagnóstico de Aplicabilidad: APLICA TOTALMENTE (Estado Actual: Nivel 2 - Gestionado deficientemente).**
• **Sustento técnico-legal:** Principio de Información (Art. 18 Ley 29733 y Art. 15 D.S. 016-2024-JUS). La UNSA mantiene convenios con EE.UU. (Purdue), España, Francia (Erasmus) y Alianza del Pacífico, pero los alumnos no son informados.

3. PERSPECTIVA DE LA UNIVERSIDAD (UNSA) — IMPLEMENTACIÓN OPERATIVA

• **Marco y Antecedentes Estatales:** *Convenios de cooperación académica internacional al amparo de la Ley Universitaria 30220.*
• **WHEN (Cuándo):** Al suscribir convenios de cooperación internacional y en las convocatorias de movilidad estudiantil.
• **HOW (Cómo):** Creando y publicando el Catálogo Institucional de Países Receptores, indicando si cuentan con nivel adecuado de protección o las garantías contractuales exigidas.
• **WHO (Quién):** Dirección de Cooperación y Relaciones Internacionales (DUCCRI) y Asesoría Jurídica.
• **WHAT (Qué entregables):** Anexo Informativo de Transferencias Internacionales incorporado en las bases de becas y convenios.
• **WHERE (Dónde se ubica):** Portal de Transparencia Estándar de la UNSA y contratos de becas de movilidad.

4. PERSPECTIVA DEL AUDITOR (Ing. Rafael) — MADUREZ: NIVEL 2 (Parcial) | RIESGO: MEDIO

• **Observaciones de Auditoría (GAP):** No se encuentra formalizado ni publicado el listado de países destinatarios derivados de los servicios cloud ni de los convenios con Purdue, Erasmus o Alianza del Pacífico, afectando la transparencia activa.
• **Recomendaciones de Remediación:** Especificar en la Política de Privacidad web los países receptores: EE.UU. (Google/Purdue), España/Francia (Erasmus), México/Colombia/Chile (Alianza del Pacífico), verificando su nivel de adecuación.

5. GUIONES DE EXPOSICIÓN ORAL — CONTROL A.1.5.3

• **Guión Como Universidad (UNSA):** *"La UNSA fomenta la movilidad global con Estados Unidos y Europa. Mapeamos formalmente cada país receptor de convenios, garantizando que cuando un estudiante viaja a Purdue o Madrid, sus datos se traten con estándares rigurosos."*
• **Guión Como Auditor (Ing. Rafael):** *"El control A.1.5.3 exige que los países destinatarios estén documentados y transparentados. Actualmente ningún estudiante agustino sabe con exactitud en qué países se procesan sus datos de intercambio o su correo cloud. La transparencia es obligatoria."*

Control A.1.5.4 — Records of transfer of PII

« Registro de transferencias y deber de cooperación ARCO » | Dominio: A.1.5 PII sharing, transfer & disclosure

TEXTO NORMATIVO ISO/IEC 27701:2025:
"The organization shall record transfers of PII to or from third parties and ensure cooperation with those parties to support future requests related to obligations to the PII principals."

1. EXPLICACIÓN GENERAL DEL CONTROL (Concepto Universal)

• **¿Qué significa en lenguaje sencillo?:** Cada vez que entregas datos a terceros (bancos, aseguradoras o clínicas), debes anotar en una bitácora qué entregaste, a quién y cuándo; y tener un contrato donde se comprometan a colaborar si el alumno pide borrar o corregir sus datos.
• ***Analogía de la vida real:*** *El cuaderno de bitácora de una garita de condominio: todo camión que retira muebles anota fecha, placa y autorización, para que si un dueño reclama, la administración sepa a quién acudir y recuperar lo debido.*

2. ¿APLICA EN LA UNSA Y CUÁL ES SU ESTADO ACTUAL?

• **Diagnóstico de Aplicabilidad: APLICA TOTALMENTE (Estado Actual: Nivel 1 - Crítico / Informal).**
• **Sustento técnico-legal:** Régimen de Encargados de Tratamiento (Arts. 50-54 D.S. 016-2024-JUS). La UNSA transfiere padrones a bancos (Banco de la Nación), aseguradoras y EsSalud sin bitácora formal ni acuerdos de cooperación ARCO.

3. PERSPECTIVA DE LA UNIVERSIDAD (UNSA) — IMPLEMENTACIÓN OPERATIVA

• **Marco y Antecedentes Estatales:** *Ley de Contrataciones del Estado (Ley 30225) y directivas de recaudación de tesorería del MEF.*
• **WHEN (Cuándo):** En cada remisión periódica de padrones y al suscribir contratos con prestadores externos.
• **HOW (Cómo):** Implementando el Libro Digital de Registro de Transferencias Externas e incorporando en cada contrato la Cláusula de Encargo de Tratamiento con Deber de Cooperación ARCO.
• **WHO (Quién):** Oficina de Abastecimiento, Dirección General de Administración (DGA), DUIC y Asesoría Jurídica.
• **WHAT (Qué entregables):** Bitácora Inmutable de Transferencias Masivas y Contratos con Acuerdos DPA anexos.
• **WHERE (Dónde se ubica):** Sistema Integrado de Gestión Administrativa (SIGA UNSA) y módulo de logs de la DUIC.

4. PERSPECTIVA DEL AUDITOR (Ing. Rafael) — MADUREZ: NIVEL 1 (Inicial) | RIESGO: ALTO

• **Observaciones de Auditoría (GAP):** La UNSA remite archivos planos con datos de matrícula a bancos y aseguradoras sin registrar el lote ni exigir contractualmente plazos de respuesta frente a reclamos ARCO de los alumnos, arriesgando responsabilidad solidaria.
• **Recomendaciones de Remediación:** Crear un log centralizado de transferencias que registre: destinatario, volumen, fecha y firma digital; incluir cláusulas obligatorias de protección de datos en todas las órdenes de servicio con terceros.

5. GUIONES DE EXPOSICIÓN ORAL — CONTROL A.1.5.4

• **Guión Como Universidad (UNSA):** *"Cada vez que la UNSA coordina con el Banco de la Nación para recaudación o con la aseguradora médica, velamos por la trazabilidad y exigimos convenios donde el proveedor se compromete a respetar la confidencialidad y cooperar con el estudiante."*
• **Guión Como Auditor (Ing. Rafael):** *"En la auditoría pedí el registro histórico de bases de datos entregadas a aseguradoras y no existía bitácora. Si un alumno ejerce su derecho de supresión y el tercero se rehúsa a borrarlo, la UNSA será sancionada solidariamente por falta de control."*

Control A.1.5.5 — Records of disclosures

« Registro de divulgaciones legales a terceros y autoridades » | Dominio: A.1.5 PII sharing, transfer & disclosure

TEXTO NORMATIVO ISO/IEC 27701:2025:
"The organization shall record disclosures of PII to third parties, including which PII has been disclosed, to whom and at what time."

1. EXPLICACIÓN GENERAL DEL CONTROL (Concepto Universal)

• **¿Qué significa en lenguaje sencillo?:** Si la organización entrega datos personales por mandato de ley (ej. policía, fiscalía, jueces, SUNAT o pedidos de transparencia pública), debe registrar exactamente qué dato dio, a quién, qué día y a qué hora.
• ***Analogía de la vida real:*** *Si la policía pide los videos de seguridad de un edificio por una investigación penal, el conserje anota el número de patrullero, el nombre del fiscal, la orden judicial y la hora exacta de entrega.*

2. ¿APLICA EN LA UNSA Y CUÁL ES SU ESTADO ACTUAL?

• **Diagnóstico de Aplicabilidad: APLICA OBLIGATORIAMENTE (Estado Actual: Nivel 2 - Gestionado de forma dispersa).**
• **Sustento técnico-legal:** Excepciones al consentimiento (Art. 14 Ley 29733) y Ley 27806 (Acceso a la Información Pública). Se responden oficios de fiscalía y juzgados, pero de manera descentralizada y sin una bitácora centralizada de datos revelados.

3. PERSPECTIVA DE LA UNIVERSIDAD (UNSA) — IMPLEMENTACIÓN OPERATIVA

• **Marco y Antecedentes Estatales:** *Portal de Transparencia Estándar y directivas del Tribunal de Transparencia (TTAIP).*
• **WHEN (Cuándo):** Inmediatamente al responder mandatos judiciales, requerimientos de fiscalía o solicitudes ciudadanas.
• **HOW (Cómo):** Tipificando en el Sistema de Gestión Documentaria (SGD UNSA) el trámite de Divulgación Legal, registrando metadatos: autoridad requirente, campos exactos entregados, fecha y firma digital autorizante.
• **WHO (Quién):** Secretaría General, Mesa de Partes Central y Dirección de Asesoría Jurídica.
• **WHAT (Qué entregables):** Libro de Registro Digital de Revelaciones y Divulgaciones Institucionales de Datos Personales.
• **WHERE (Dónde se ubica):** Sistema de Gestión Documentaria (SGD UNSA) y repositorio de oficios respondidos.

4. PERSPECTIVA DEL AUDITOR (Ing. Rafael) — MADUREZ: NIVEL 2 (Parcial) | RIESGO: ALTO

• **Observaciones de Auditoría (GAP):** Decanatos y directores de escuela responden directamente pedidos policiales remitiendo direcciones y notas sin filtro legal previo de Secretaría General ni registro del lote entregado, arriesgando responsabilidades penales y civiles.
• **Recomendaciones de Remediación:** Emitir resolución rectoral que prohíba a facultades entregar datos directamente; canalizar todo requerimiento por Secretaría General con registro obligatorio en la Bitácora del SGD conforme a A.1.5.5.

5. GUIONES DE EXPOSICIÓN ORAL — CONTROL A.1.5.5

• **Guión Como Universidad (UNSA):** *"Toda entrega de información solicitada por el Poder Judicial o el Ministerio Público se canaliza formalmente por Secretaría General, quedando registrado el oficio judicial, los datos provistos y la fecha de notificación conforme a ley."*
• **Guión Como Auditor (Ing. Rafael):** *"He constatado que decanos entregan listas con domicilios a comisarías locales por simple solicitud escrita sin registrar qué datos específicos se revelaron. El control A.1.5.5 exige un registro estricto: qué dato, a quién y cuándo."*

Conclusiones Finales y Dictamen del Auditor Líder

1. DIAGNÓSTICO INTEGRAL DE LAS SECCIONES A.1.4 Y A.1.5:
La evaluación técnica de los 13 controles normativos evidencia que la Universidad Nacional de San Agustín (UNSA) posee una madurez promedio de 1.62 sobre 5 (Nivel Inicial con prácticas gestionadas informalmente). Si bien existen capacidades técnicas destacables —como la interoperabilidad con RENIEC vía PIDE para títulos y el uso de canales HTTPS principales—, la institución adolece de gobernanza institucional formal en privacidad desde el diseño y por defecto.

2. PRINCIPALES BRECHAS CRÍTICAS IDENTIFICADAS (HALLAZGOS MAYORES):
• Flujo Transfronterizo no Notificado (Control A.1.5.2): La operación de correo y storage de más de 27,000 agustinos en la nube internacional (Google/Azure) no cuenta con inscripción ante la ANPDP, constituyendo infracción grave bajo el D.S. 016-2024-JUS.
• Falta de Protocolos de Disposición y Borrado Seguro (Control A.1.4.9): Discos duros y equipos patrimoniales en almacén carecen de borrado certificado bajo estándares forenses (NIST 800-88), con riesgo severo de fuga de información.
• Conservación Indefinida de Postulantes y Temporales (Controles A.1.4.6 y A.1.4.7): Se almacenan más de 120,000 registros con fotos y huellas de postulantes de procesos cerrados y más de 45 GB de temporales desprotegidos en servidores web.
• Ausencia de Bitácoras de Transferencias a Terceros (Controles A.1.5.4 y A.1.5.5): Se comparten datos con bancos y aseguradoras sin contratos DPA de cooperación frente a Derechos ARCO ni registro unificado de requerimientos judiciales.

3. ARTICULACIÓN ESTRATÉGICA CON EL PROYECTO TIF-DSAR:
La implementación de estos 13 controles establece el cimiento indispensable para el proyecto de tesis TIF-DSAR (Agente de IA para Solicitudes de Derechos de los Titulares). El agente de IA requiere que las bases de datos estén depuradas, minimizadas, catalogadas en sus transferencias y sincronizadas con las entidades terceras para poder ejecutar solicitudes de rectificación, acceso o supresión con plena validez técnico-jurídica.

4. DICTAMEN OFICIAL DE AUDITORÍA (ING. RAFAEL, LEAD AUDITOR):
Se emite dictamen de 'NO CONFORMIDAD MAYOR' respecto a los controles A.1.5.2 (Flujo Transfronterizo) y A.1.4.9 (Disposición Segura), y 'NO CONFORMIDAD MENOR' en los restantes controles. Se otorga a las autoridades de la UNSA un plazo perentorio de 60 días calendario para la regularización de registros ante el Ministerio de Justicia y la aprobación de las directivas de borrado seguro.

CERTIFICACIÓN DEL INFORME PERICIAL DE AUDITORÍA

Ing. Rafael — Auditor Líder en Ciberseguridad y Privacidad
MSc. Seguridad de la Información | Lead Auditor ISO/IEC 27001 & ISO/IEC 27701
Certified Information Systems Auditor (CISA) | CRISC Certified
Colegio de Ingenieros del Perú (CIP) — Capítulo de Ingeniería de Sistemas